1. Purpose and Scope
This document establishes mandatory security baselines for all Kubernetes clusters operated by Acme Corp, including prod

2. Access Control and Session Policies
All administrative cluster access requires hardware-backed multi-factor authentication (MFA).
Direct cluster admin role bindings are prohibited; engineers must use just-in-time access via AWS IAM Identity Center with a
Break-glass access is logged directly to CloudTrail and triggers a real-time notification to the InfoSec Slack channel (#infose

3. Secrets Management and Encryption Standards
All Kubernetes Secrets at rest must be encrypted using AWS KMS customer managed keys.
KMS keys must be configured for automatic rotation every 90 days. Secrets stored in Git or Helm values files are strictly forb
External Secrets Operator (ESO) is the only approved mechanism for synchronizing secrets from AWS Secrets Manager int

4. Vulnerability Remediation SLAs
Container image vulnerabilities detected by Trivy and ECR vulnerability scanning must be remediated according to the follow

Severity | Definition | Remediation SLA
CRITICAL | Remote code execution or privilege escalation | 24 hours
HIGH | Denial of service or credential exposure | 7 calendar days
MEDIUM | Low-impact vulnerabilities | 30 calendar days
LOW | Informational or hardening findings | 90 calendar days

Images containing unpatched CRITICAL vulnerabilities older than 24 hours are automatically blocked by the Kyverno admis

5. Audit Log Retention and Compliance Cadence
Kubernetes audit logs and AWS CloudTrail events must be forwarded to an immutable S3 Glacier vault with Object Lock in
Audit logs must be retained for a minimum of 365 days (1 year), contrasting with operational application logs which are retai
Compliance access reviews are conducted on a monthly basis by the Security Assurance team.

6. Incident Escalation: Security vs Operational Incidents
Security incidents (SEC-1) require an immediate response target of 10 minutes and direct paging of the CISO on-call, where